المحاضرة السادسة في حوكمة الأمن السيبراني — إدارة المخاطر السيبرانية — الملخص الدراسي

منصة القيادة الرقمية · الملخصات الدراسية

ملخص المحاضرة السادسة في حوكمة الأمن السيبراني — إدارة المخاطر السيبرانية

الملخص الأكاديمي

ملخص المحاضرة السادسة في حوكمة الأمن السيبراني — إدارة المخاطر السيبرانية

المصدر: المحاضرة السادسة في حوكمة الأمن السيبراني — إدارة المخاطر السيبرانية.pdf

تؤسس المحاضرة لإدارة المخاطر السيبرانية: صيغة الخطر وعناصره الثلاثة، ودورة حياة إدارة المخاطر، والمقارنة بين التحليل النوعي والكمي، وخيارات المعالجة الأربعة، ومصفوفة تقييم المخاطر، والتمييز بين شهية المخاطر وتحملها، وأبرز الأطر العالمية.

أولًا: صيغة الخطر السيبراني وعناصره

• صيغة الخطر (Risk Formula): الخطر = التهديد × الثغرة × التأثير. فالخطر السيبراني لا ينشأ إلا عند اقتران تهديد نشط بثغرة أمنية تؤدي إلى تأثير مباشر على أهداف المؤسسة؛ وغياب أي عنصر يُسقط الخطر.

• الأصول (Assets): البيانات والأنظمة والبنية التحتية ذات القيمة الحيوية للمؤسسة، وهي محل الحماية.

• الثغرات (Vulnerabilities): نقاط الضعف البرمجية أو التنظيمية التي يمكن استغلالها.

• التهديدات (Threats): الأحداث الحتمية أو المحتملة التي قد تسبب ضررًا للأصول.

ثانيًا: دورة حياة إدارة المخاطر (وفق ISO 31000 وNIST)

• تحديد المخاطر: حصر الأصول والتهديدات والثغرات الحالية، وهي الخطوة الأولى في الدورة.

• التحليل والتقييم: قياس احتمالية الحدوث وتحديد شدة الأثر المتوقع.

• المعالجة: تطبيق الضوابط والتخفيف وفق الأولويات.

• المراقبة والمراجعة: متابعة مستمرة لتقييم كفاءة الضوابط، وهي المرحلة الأخيرة التي تغذّي الدورة من جديد.

ثالثًا: التحليل النوعي مقابل التحليل الكمي

• التحليل النوعي (Qualitative): يستخدم مقاييس وصفية (مرتفع، متوسط، منخفض)، ويتميز بسرعة التنفيذ وقلة التكلفة، ويُستخدم للتقييم المبدئي وتحديد الأولويات العامة.

• التحليل الكمي (Quantitative): يستخدم قيمًا مالية ورقمية محددة مثل SLE وALE، ويتميز بالدقة العالية ودعم قرارات الاستثمار، ويُستخدم في قرارات ميزانيات الأمان الحساسة.

رابعًا: خيارات معالجة المخاطر ومصفوفة التقييم

• التخفيف (Mitigation): تطبيق ضوابط أمنية لتقليل احتمالية الخطر أو أثره.

• الاجتناب (Avoidance): إيقاف النشاط أو التقنية المسببة للخطر نهائيًا.

• النقل (Transfer): تحويل الخطر إلى طرف ثالث كالتأمين السيبراني.

• القبول (Acceptance): قبول الخطر المتبقي ما دام ضمن مستويات التحمل.

• مصفوفة تقييم المخاطر: تربط احتمالية الحدوث بتأثير الخطر لتحديد الأولويات؛ فاجتماع الاحتمالية المرتفعة مع التأثير المرتفع يصنّف الخطر «حرجًا جدًا»، ويتدرج التصنيف نزولًا إلى المنخفض.

خامسًا: شهية المخاطر وتحملها والأطر العالمية

• شهية المخاطر (Risk Appetite): مستوى الخطر الكلي الذي تستعد المؤسسة لقبوله لتحقيق أهدافها الاستراتيجية.

• تحمل المخاطر (Risk Tolerance): مقدار الانحراف المقبول عن شهية المخاطر المحددة في الحالات التشغيلية؛ أي أن الشهية حدّ استراتيجي عام والتحمل هامش تشغيلي حوله.

• NIST SP 800-30: إطار متخصص لإجراء تقييمات المخاطر الشاملة لنظم المعلومات.

• ISO/IEC 27005: المعيار الدولي لإدارة مخاطر أمن المعلومات، وهو مكمل لمنظومة ISO 27001.